PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation des flux avec IPsec

03-360 ANSSI - Recommandations de sécurité relatives à IPsec — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. IPsec assure la protection de la confidentialité, de l'intégrité et de l'anti-rejeu des flux au niveau de la couche 3 du modèle OSI.
2. Le protocole ESP est recommandé car il assure la confidentialité contrairement à AH qui ne gère que l'intégrité et l'authentification.
3. L'utilisation de la PFS garantit qu'un attaquant ne peut pas déchiffrer des échanges antérieurs même s'il obtient les secrets cryptographiques ultérieurement.

Présentation, usages et comparaison d'IPsec

Notion	À retenir
Présentation générale	Protège les flux en **couche réseau** (**RFC 4301 à 4309**). Technologie **mature**, peu coûteuse, prise en charge **nativement** par équipements et OS.
Cas d'usage	**Nomadisme** (poste ↔ équipement de sécurité), **site à site**, protection d'équipements faibles (**SCADA**, protocoles non sûrs), **défense en profondeur** ; accès distant : produits **certifiés/qualifiés ANSSI**.
Comparaison avec TLS	IPsec préféré : crypto **dans le noyau** (surface réduite) et **Encrypt-then-MAC** (TLS : MAC-then-Encrypt). TLS reste adapté à un protocole applicatif (**HTTPS, IMAPS, LDAPS**).

Fonctionnement d'IPsec

Notion	À retenir
AH et ESP	**AH** : intégrité/authentification sans chiffrement (incompatible NAT). **ESP** : confidentialité, intégrité et authentification. **ESP** est recommandé, avec contrôle d'intégrité activé.
Modes transport/tunnel	**Transport** : greffe AH/ESP sur paquet IP initial. **Tunnel** : nouveau paquet IP avec deux en-têtes. Réduit le **MTU** de **50 à 100 octets**.
Politiques et SA	Éviter les **Security Policy** à usage **facultatif** (attaque par **dégradation**) : n'autoriser que les flux sécurisés. Politique **uniforme** aller/retour.

Comparaison des modes et protocoles

	Mode Transport	Mode Tunnel
En-tête IP	Pas de duplication de l'en-tête	Deux en-têtes IP (externe et interne)
Adressage	Non masqué	Masque l'adressage interne du réseau privé
Impact réseau	Consommation normale	Consommation plus importante et réduction du **MTU**

Établissement d'un lien IPsec

Notion	À retenir
Choix clé/IKE	Fixer **a priori** algorithmes et tailles de clés (IKE pour l'échange seul) ou restreindre la négociation. **IKEv2** (`RFC 5996`). Clé **manuelle** fortement déconseillée (ni **PFS** ni authentification crypto ; tests seulement).
Authentification	Phase 1 (**ISAKMP/IKE SA**) : **RSA** (idéal avec PKI) ou **PSK**. **PSK** réservé aux tests ; entropie **< 100 bits** est risquée.
SP et NAT	Configuration **statique** privilégiée. Si **NAT** : **AH** inutilisable, activer **NAT-Traversal** (encapsulation **IKE** et **ESP** en **UDP port 4500**).

Paramètres de sécurité IPsec

Notion	À retenir
La mise en œuvre de la PFS	Utiliser **IKE** avec **Diffie-Hellman éphémère** ou courbe elliptique (jamais **clé manuelle**). Activer en **phase 2** et renouveler les clés (ex: toutes les **heures** et tous les **100 Go**).
Le choix des algorithmes	**Fortement déconseillés** : **MD5**, **DES**, **RSA < 2048**, **ECDSA < 200 bits**. **Déconseillés** si alternative : **3DES**, **SHA-1**, **ECDSA < 256**. **DH 1 et 2** à remplacer par **14, 15** ou courbes **≥ 256 bits**. Préférer **AES**, **SHA-2**.

Pièges et confusions

- ⚠ Confondre AH et ESP : AH ne fournit pas de confidentialité.
- ⚠ Oublier que le contrôle d'intégrité d'AH est incompatible avec la traduction d'adresses (NAT).
- ⚠ Utiliser une Security Policy avec un usage facultatif, ce qui expose à une attaque par dégradation (downgrade attack).
- ⚠ Croire que la sécurité est garantie par l'algorithme le plus fort alors qu'elle dépend de l'algorithme le plus faible parmi ceux acceptés.
- ⚠ Utiliser des clés manuelles en pensant être sécurisé alors qu'elles ne permettent pas la PFS ni l'authentification cryptographique.

Sigles et définitions

IPsec	Suite de protocoles permettant de protéger en confidentialité, intégrité et anti-rejeu un flux au niveau de la couche réseau.
AH	Protocole numéro 51 assurant l'intégrité et l'authentification des paquets IP, sans confidentialité.
ESP	Protocole numéro 50 assurant la confidentialité, l'intégrité et l'authentification des paquets.
IKE	Protocole d'échange de clés utilisé pour négocier dynamiquement les paramètres d'une Security Association.
Security Association (SA)	Regroupe les données de contexte d'un lien unidirectionnel, identifiée par un SPI.
PFS	Garantit qu'un attaquant obtenant ultérieurement les secrets cryptographiques ne peut pas déchiffrer des échanges antérieurs.
NAT-Traversal (NAT-T)	Encapsule le trafic IKE puis ESP dans des datagrammes UDP sur le port 4500.

Auto-test

1. Quel protocole IPsec est incompatible avec les mécanismes de traduction d'adresses ?
2. Quel port UDP est utilisé par le NAT-Traversal ?
3. Quel mode IPsec masque l'adressage interne du réseau privé ?
4. Quelle est la conséquence d'un usage facultatif d'IPsec dans une Security Policy ?
5. Quel protocole doit être privilégié pour l'établissement d'un lien IPsec ?

Réponses : **1.** AH · **2.** 4500 · **3.** Mode Tunnel · **4.** Une attaque par dégradation (downgrade attack) · **5.** IKEv2

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.